

BRIGHTCARE HEALTH CLINIC

PASSWORD & AUTHENTICATION POLICY

Information Security | Access Control

Document ID	BCHC-IS-POL-002
Version	1.0
Classification	CONFIDENTIAL — Internal Use Only
Owner	Information Security Team
Applies To	All BrightCare Health Clinic Staff, Contractors & Third Parties
Review Cycle	Annual or following a credential compromise incident
Effective Date	June 2026
Prepared By	Bikash Raya — Cybersecurity Portfolio Project
Frameworks	NIST CSF NIST SP 800-63B HIPAA Security Rule 45 CFR 164.308

Purpose

This policy establishes requirements for the creation, use, and management of passwords and authentication mechanisms to protect BrightCare Health Clinic systems, patient data (PHI), and organizational information assets from unauthorized access.

1. Scope

This policy applies to:

- All employees, contractors, volunteers, and third-party vendors
- All clinic-owned and personally-owned devices used for clinic work (BYOD)
- Microsoft 365, Exchange Online, and all cloud SaaS platforms
- Electronic Health Record (EHR) systems and clinical applications
- On-premise systems and Active Directory environments
- Remote access systems (VPN, Remote Desktop Protocol)
- Privileged accounts (system administrators, IT staff, clinic managers)

2. Policy Statement

BrightCare Health Clinic requires all users to authenticate using secure methods that protect patient Protected Health Information (PHI) and organizational systems from unauthorized access. All passwords must be created, stored, and managed in accordance with NIST SP 800-63B Digital Identity Guidelines and HIPAA Security Rule access control requirements (45 CFR 164.312(a)).

Multi-Factor Authentication (MFA) must be enabled on all systems that access PHI or are accessible from outside the clinic network.

3. Password Requirements

3.1 Length Requirements

Standard User Accounts	Minimum 12 characters
Privileged / Admin Accounts	Minimum 16 characters
EHR System Accounts	Minimum 14 characters (PHI access)
Recommendation	Use passphrases (e.g., four or more random words) for easier memorability and greater security

NIST SP 800-63B

NIST 800-63B recommends prioritizing password length over complexity rules. Longer passwords are statistically more resistant to brute force attacks than short, complex passwords.

3.2 Complexity Guidelines

- Passwords may include letters, numbers, and special characters
- Passwords must NOT be based on easily guessable information (name, date of birth, clinic name, pet names)
- Passwords must NOT contain the username or display name
- Passwords must NOT appear on commonly-used or breached password lists

NIST Alignment

In alignment with NIST SP 800-63B, BrightCare Health Clinic does NOT require mandatory periodic password complexity changes unless a compromise is suspected. Forced arbitrary rotation encourages weaker password choices.

3.3 Prohibited Password Practices

All users are strictly prohibited from:

- Sharing passwords with colleagues, managers, or IT staff
- Reusing clinic passwords on personal or external websites
- Storing passwords in plain text (emails, spreadsheets, sticky notes)
- Using the same password across multiple clinic systems
- Transmitting passwords via email, instant message, or phone
- Using passwords previously identified in data breaches

4. Multi-Factor Authentication (MFA)

MFA is mandatory for all access to systems containing PHI and for all remote access to clinic systems. MFA must be enforced regardless of location.

4.1 Where MFA is Required

- **Microsoft 365 / Exchange Online (email and productivity tools)**
- **Electronic Health Record (EHR) system**
- **Azure Active Directory / Microsoft Entra ID**
- **VPN and Remote Desktop access**
- **All privileged administrator accounts**
- **Any cloud SaaS platform storing clinic or patient data**

4.2 Approved MFA Methods

Method	Security Level	Notes
Microsoft Authenticator App (TOTP)	Preferred	Approved for all staff. App-based time-based OTP.
Hardware Security Key (FIDO2)	Highest	Required for privileged/admin accounts.
Biometric Authentication	High	Approved where supported by device.
SMS / Phone Call OTP	Low -- Avoid	Only permitted if no other MFA method is available. SIM-swap risk.

5. Account Lockout & Brute Force Protection

Failed Login Threshold	5 consecutive failed attempts triggers account lockout
Standard Account Lockout	15 minutes automatic lockout

Privileged Account Lockout	Immediate lockout -- manual unlock by IT Security required
Failed Attempts Monitoring	All failed login attempts logged to SIEM / Azure AD Sign-in Logs
Alert Threshold	Security alert generated at 3+ consecutive failures on EHR or PHI systems

HIPAA Requirement

HIPAA 45 CFR 164.312(a)(2)(iii) requires that automatic logoff procedures be implemented for systems containing PHI. Account lockout controls directly support this requirement.

6. Privileged Account Requirements

Privileged accounts (system administrators, database administrators, IT staff, clinic managers with elevated access) are subject to the following additional controls:

- Privileged accounts must use separate credentials from standard user accounts
- MFA using hardware security keys (FIDO2) is required for all privileged accounts
- Privileged accounts must NOT be used for routine activities such as email or web browsing
- Just-in-Time (JIT) access elevation is recommended where technically feasible
- Privileged account sessions must be logged and reviewed monthly
- Privileged access must be reviewed and recertified quarterly

7. Password Storage & Transmission

- Passwords must be stored using strong cryptographic hashing (bcrypt, Argon2, or PBKDF2)
- Passwords must never be stored in plain text in any database, log file, or configuration file
- Passwords must never be transmitted in plain text -- TLS 1.2 or higher is required
- Hardcoded credentials in scripts, source code, or configuration files are strictly prohibited
- A clinic-approved password manager must be used to store and generate strong passwords

8. Password Changes

- Passwords must be changed immediately upon suspected or confirmed compromise
- Passwords must be changed when instructed by the Security team following an incident
- Routine forced periodic password rotation is NOT required (aligned with NIST 800-63B)
- Password history enforcement: users cannot reuse any of the last 10 passwords

9. Authentication Monitoring & Logging

The following authentication events must be logged and monitored in accordance with HIPAA 45 CFR 164.312(b) Audit Controls:

- Successful logins (all accounts)
- Failed login attempts
- Account lockouts
- MFA challenges and failures

- Privileged account usage
- Password resets (self-service and administrator-initiated)
- After-hours access to EHR systems (flagged for review)

Logs must be retained for a minimum of 6 years in accordance with HIPAA documentation retention requirements (45 CFR 164.316(b)(2)).

10. Credential Compromise Reporting

All staff must immediately report any of the following to the IT/Security team:

- Suspected phishing email or credential harvesting attempt
- Suspicious login notification received from Microsoft or any system
- Accidental disclosure of password to another person
- Belief that a password has been compromised

Upon receiving a credential compromise report, the Security team will:

1. Reset the affected credentials within 1 hour
2. Revoke all active sessions
3. Force MFA re-registration on all devices
4. Review sign-in logs for unauthorized access
5. Assess potential PHI exposure and initiate HIPAA Risk Assessment if required
6. Document the incident per the Phishing Incident Response Playbook (BCHC-IR-PB-001)

11. Enforcement

All staff are required to comply with this policy as a condition of employment and system access. Failure to comply may result in:

- Immediate temporary suspension of system access
- Disciplinary action up to and including termination of employment
- Termination of contractor or vendor agreements
- Legal consequences where applicable
- Regulatory action by HHS Office for Civil Rights (OCR) in cases of HIPAA non-compliance

12. Framework Alignment

NIST Cybersecurity Framework (CSF)

Control ID	Control Name	Policy Application
PR.AC-1	Identity and credential management	Password requirements, MFA, privileged account controls
PR.AC-7	User authentication	MFA mandate, lockout policy, authentication monitoring
PR.IP-1	Security policies established	This policy document
DE.CM-7	Monitoring unauthorized access	Authentication logging and alerting requirements

Additional Framework References

NIST SP 800-63B	Digital Identity Guidelines -- Authentication and Lifecycle Management
HIPAA 45 CFR 164.308(a)(5)	Security Awareness and Training -- password management training
HIPAA 45 CFR 164.312(a)	Access Control -- unique user identification, automatic logoff
HIPAA 45 CFR 164.312(b)	Audit Controls -- logging authentication events
HIPAA 45 CFR 164.312(d)	Person Authentication -- verifying user identity

ISO/IEC 27001:2022 Alignment

This policy supports the following ISO/IEC 27001:2022 Annex A controls:

ISO 27001 Control	Control Name	Application
A.5.16	Identity management	User account creation, management and access provisioning
A.5.17	Authentication information	Password requirements, storage, transmission and management
A.5.18	Access rights	Privileged account controls and access review procedures
A.8.2	Privileged access rights	Separate credentials, FIDO2 MFA, JIT access for admin accounts
A.8.5	Secure authentication	MFA mandate, approved methods, account lockout policy
A.8.15	Logging	Authentication event logging and 6-year retention requirements
A.8.18	Use of privileged utility programs	Privileged account monitoring and quarterly reviews